Registro de supuestos del diseño

Implementación de un SOC Nivel 1 — PagoClaro Fintech S.A.S. (C05)

IDENTIFICACIÓN	DETALLE
Empresa ficticia	PagoClaro Fintech S.A.S.
Caso / fase	C05 / Fase 0 — Alcance y ética
Documento	Registro de supuestos adicionales del proyecto
Estado	Propuesta de diseño. No acredita instalación ni pruebas ejecutadas.
Responsable / fecha	[Nombre del estudiante] · [Fecha de elaboración]

1. Finalidad y criterio de registro

El presente documento identifica decisiones y condiciones que no están fijadas expresamente en la ficha C05 y que se adoptan para diseñar un laboratorio representativo. Estos supuestos complementan el inventario, la matriz de riesgos, la carta de autorización y el alcance. Su aplicación queda sujeta a verificación técnica y, cuando corresponda, a validación académica.

2. Datos obligatorios que no se modifican

REFERENCIA DEL CASO	CONDICIÓN FIJA
Operación	Fintech de pasarela de pagos y billetera digital; modalidad híbrida y madurez media-alta.
Personal y parque tecnológico	10 empleados y 20 equipos: 8 estaciones Windows 11, 3 portátiles Windows 11, 5 portátiles macOS y 4 servidores Ubuntu Server.
Infraestructura	Núcleo transaccional en IaaS, API de pagos expuesta y conectividad VPN con la sede.
Activos y riesgos críticos	API de pagos, base de datos transaccional, bastión y llaves de cifrado; fraude, toma de cuentas y accesos indebidos.
Restricción económica	CAPEX máximo COP 70 millones y OPEX máximo COP 5 millones mensuales (topes académicos, no precios reales).

3. Supuestos propuestos para el diseño

ID	ÁMBITO	SUPUESTO DE DISEÑO	VERIFICACIÓN / LÍMITE
SUP-01	Identificación de equipos	Se usarán hostnames únicos con el código C05 (PC-C05-01, MAC-C05-01, SRV-C05-APP, etc.).	Verificar que coincidan en inventario, diagramas, agentes y evidencias.
SUP-02	Responsables ficticios	Los activos se asignarán a roles como Operaciones, Soporte TI, Desarrollo, Administrador TI, Administrador BD y Administrador Cloud.	No emplear nombres ni datos personales reales.
SUP-03	Segmentación de red	Se proponen VLAN 10 Operaciones (192.168.10.0/24), 20 Servidores (192.168.20.0/24) y 30 Gestión/Seguridad (192.168.30.0/24).	Es un diseño empresarial; no implica VLAN físicas implementadas.
SUP-04	Ubicación del bastión	El bastión se ubicará lógicamente en el segmento de Gestión/Seguridad. Los otros tres Ubuntu Server representan aplicación, réplica de BD y respaldo.	La distribución mantiene exactamente cuatro servidores corporativos.

SUP-05	Red virtual del laboratorio	Se propone VirtualBox Host-only 192.168.56.0/24, con Wazuh .10, Windows .20 y Ubuntu de pruebas .30. NAT temporal solo para instalación y actualizaciones.	Confirmar conectividad real; no usar modo puente para pruebas contra terceros.
SUP-06	Alcance de virtualización	Se implementará un conjunto representativo de máquinas, no 20 VM. Los nodos exclusivos del SOC son infraestructura de laboratorio adicional.	Documentar por separado el diseño para 20 activos y las VM realmente desplegadas.
SUP-07	Modalidad de operación N1	Se propone N1 interno de lunes a viernes, 08:00–18:00 (America/Bogota), con escalamiento a un rol N2 definido por el proyecto.	Fuera de ese horario puede continuar la recolección automática; no afirmar vigilancia humana 24/7.
SUP-08	SIEM y crecimiento	Se propone Wazuh todo-en-uno para la práctica y un diseño de cobertura de 20 equipos, con margen objetivo de 25–30 % para crecimiento.	Validar recursos, retención y resultados del laboratorio en la Fase 1 y siguientes.
SUP-09	Protección EDR/XDR	Se evaluará una edición empresarial de Kaspersky con consola, agentes y exportación de eventos compatible con el SIEM.	La edición, las licencias y la compatibilidad con macOS/Linux permanecen por confirmar.
SUP-10	Gestión de incidentes cloud	GLPI se desplegará en una instancia cloud académica con HTTPS y datos ficticios; la creación de tickets de alertas será manual.	Proveedor, dominio, capacidad y controles finales se documentarán cuando se contrate o instale.
SUP-11	Servicios y activos en nube	La API y el núcleo transaccional se representan como servicios lógicos asociados al caso; no se presume la existencia de servidores nuevos adicionales a los 20.	La distribución exacta de responsabilidades cloud y la fuente de logs se definirá posteriormente.
SUP-12	Generación de eventos	La alerta VPN geográficamente anómala se ensayará con registros sintéticos; los escenarios FIM y privilegios se probarán solo en VM propias.	Marcar de forma explícita los eventos simulados y guardar evidencia original de la detección.
SUP-13	Política inicial de registros	Como punto de partida se propone disponer de 90 días de alertas consultables y 12 meses archivados, sujeto a capacidad y obligaciones aplicables.	Es una hipótesis de retención, no un requisito legal afirmado; justificar y ajustar el valor en Fase 1.
SUP-14	Dispositivos perimetrales	El NGFW, el switch de 24 puertos y los dos puntos de acceso se incluirán en la arquitectura. El NGFW será evaluado y cotizado, sin compra ni instalación física.	No presentar sus logs o políticas como eventos reales hasta contar con una fuente autorizada.
SUP-15	Fuentes de evidencia	Se utilizarán capturas, logs, exportaciones y archivos de configuración generados en el laboratorio, con datos y usuarios ficticios.	Ocultar contraseñas, tokens, llaves, direcciones públicas reales y demás secretos.

4. Condiciones y pendientes de validación

- La carta de autorización debe contar con validación del docente antes de considerar autorizadas las pruebas.
- El fabricante y la edición de Kaspersky, la instancia de GLPI y las tres cotizaciones reales del NGFW todavía no están determinados.
- Las IP, VLAN, hostnames, roles y horarios propuestos pueden ajustarse, siempre que se actualicen de forma consistente el inventario, el diagrama y el informe.
- La arquitectura final y las condiciones de retención deben justificarse en la Fase 1; el funcionamiento se acreditará únicamente con evidencias de ejecución en fases posteriores.

5. Declaración para la Fase 0

Los elementos SUP-01 a SUP-15 son supuestos académicos documentados para el Caso C05. No alteran la cantidad ni la distribución de los equipos asignados por el docente. Ningún supuesto se presenta como configuración operativa o resultado de prueba hasta su implementación y validación con evidencia propia.

Fuente base: Parcial_SOC_N1_Etica_Hacking, ficha detallada C05 (p. 18); Fase 0 (pp. 39–40); Fase 1 (pp. 41–42).

Observación: La aprobación del docente no está implícita en este registro.